



ข้อปฏิบัติในการปิดกั้นการเข้าถึงเนื้อหาที่ถูกปิดรับการเข้าถึงโดย GDCC Security Operation Center

ตามข้อกำหนดมาตรฐาน TOP OWASP 10:2021 มีสาเหตุดังนี้

TOP OWASP 10:2021		สาเหตุ/รายละเอียด	อ้างอิง
1.	Injection	การโจมตีโดยแทรกคำสั่ง(Code) เข้าไปที่แอปพลิเคชันเป้าหมาย จะมีได้ทั้งแบบ SQL หรือ NoSQL หรือแทรกผ่านคำสั่งระดับ OS และ การแทรกคำสั่งผ่าน LDAP	
2.	Broken Authentication	การโจมตีที่เกี่ยวกับการ login โดยใช้ Username และ Password หรือ การใช้ Login Key หรือ การใช้ session token	
3.	Sensitive Data Exposure	การโจมตีแบบเจาะจงมาที่การส่งข้อมูลส่วนตัว , บัตรประชาชน หรือ บัตรเครดิต แล้วปลอมแปลงข้อมูลนั้นๆ โดยสามารถทำได้ทาง Web Application และ APIs(Application Programming Interface[API] : ช่องทางเชื่อมต่อระหว่างเว็บไซต์หนึ่งไปยังอีกเว็บไซต์หนึ่ง	
4.	XML External Entities(XXE)	การโจมตีผ่าน SOAP Web Service โดยการส่งคำสั่งเข้าไปใน XML document ของเครื่องเป้าหมาย เพื่อให้ฝั่ง Server ประมวลผลการโจมตีทาง XXE	
5.	Broken Access control	การโจมตีผ่านทางสิทธิ์ของบัญชีผู้ใช้ในระบบ เช่น การให้สิทธิ์บางอย่างกับ User มากเกินไป จนทำให้สามารถเจาะได้ทั้งระบบ หรือ User ตัวเองไม่มีสิทธิ์ในการแก้ไขบางอย่างจึงไปใช้ User ของคนอื่นที่มีสิทธิ์มากกว่ามาทำ จนทำให้เกิดช่องโหว่ในการโจมตีจาก Hacker	
6.	Security misconfigurations	การโจมตีผ่านช่องโหว่การตั้งค่าระบบ แบบใช้ค่าเริ่มต้น ทำให้สามารถคาดเดาการตั้งค่าของระบบได้ หรือ การตั้งค่าระบบไม่ปลอดภัย ใส่ผิดตำแหน่ง(Path) กำหนดสิทธิ์ไม่ถูกต้อง หรือ การใส่ค่า Config เพิ่มเติมจากที่มีอยู่เพื่อทำงานบางอย่างโดยไม่คำนึงถึงความปลอดภัย การไม่ใส่ HTTP Headers การส่ง Output app log ที่มีข้อมูลส่วนบุคคลมากเกินไป เพราะฉะนั้นจึงต้อง กำหนดค่าระบบปฏิบัติการและแอปพลิเคชันทั้งหมดอย่างปลอดภัย และ ติดตั้ง/อัปเดต ในเวลาที่เหมาะสม	
7.	Cross Site Scripting(XSS)	- Reflected XSS คือการโจมตีแบบชั่วคราวโดยการส่ง Script ไปพร้อมกับ link URL เมื่อเป้าหมาย คลิก link ตัว Script ก็จะทำงานทันที	

		- Stored XSS คือ การโจมตีแบบถาวร คือ การฝัง Script ไว้ที่ Web browser และ Script สามารถเข้าไปประมวลผลได้ - DOM-based XSS คือ การแก้ไข Framework ของ DOM เพื่อรับข้อมูลจาก User ที่ทำงานปกติ มาแสดงที่หน้า Browser ที่เราต้องการ	
8.	Insecure Dessrialization	การโจมตีโดยการส่ง Remote Code เข้ามาเพื่อให้ช่องโหว่ที่เกิดการเปลี่ยนแปลงข้อมูลหรือถอดรหัสข้อมูลใน Application ที่ผิดพลาด การโจมตีทำได้ดังนี้ สามารถลบหรือเปลี่ยนแปลงข้อมูลที่ถูกเข้ารหัสไว้ โจมตีแบบ Injection ได้ทั้งแบบ SQL หรือ NoSQL หรือแทรกผ่านคำสั่งระดับ OS และ LDAP เพิ่มสิทธิ์การเข้าถึงของ User ให้สามารถ Insert/Update/Delete หรือ ได้สิทธิ์สูงสุดเท่า Admin	
9.	Using Components with Known Vulnerabilities	เป็นการโจมตีผ่านช่องโหว่ของการใช้ Software และ Hardware ที่ถูกรายงานและเผยแพร่ไว้เป็นสาธารณะแล้ว โดยมาตรฐานจะอ้างอิงตามช่องโหว่ที่ประกาศที่ CVE ประกาศ	https://cve.mitre.org/
10.	Insufficient Logging and Monitoring	เป็นการโจมตีจากช่องบันทึก และ แสดงผล log ของการโจมตีที่ไม่เพียงพอสำหรับการวิเคราะห์หาความเสี่ยง และการตรวจสอบที่ไม่ครอบคลุมถึงเส้นทางการโจมตี จากกลุ่ม Hacker เช่น Hacker ใช้วิธีหลากหลายรูปแบบในการเจาะระบบ โดยการโจมตีนั้นๆจะมี access log รวมถึงวิธีการเข้าถึง ถ้าฝั่งของ Admin Server ไม่เข้ามาตรวจสอบ log ว่ามีใครพยายามเข้ามาในระบบบ้าง และไม่ทำการลบเส้นทางหรือ History log ของ Hacker ที่ทำได้ ก็จะทำให้ Hacker โจมตีระบบได้มากยิ่งขึ้น	

ดังนั้น เพื่อความปลอดภัยทางผู้ดูแลระบบจะต้องหมั่นอัปเดต Patch ของ Web Server และ Software Third Party ที่ใช้ในการพัฒนาระบบเว็บไซต์อยู่เสมอ และหากมี Coding ที่สุ่มเสี่ยงต่อการถูกเจาะระบบก็จำเป็นต้องเข้าไปแก้ไข Coding เหล่านั้นให้มีความปลอดภัยมากขึ้น **อ้างอิง :** <https://hrod-it.ipst.ac.th/2021/02/15/owasp/>

คำแนะนำเพิ่มเติมในการแก้ไขเบื้องต้น

1. ควรเชื่อมต่อ VPN ด้วย FortiClient และเข้าแก้ไขเนื้อหาเว็บไซต์
2. ควรเชื่อมต่อไปยัง Web Server และเข้าแก้ไขเว็บไซต์เนื้อหาภายในเครื่อง Server

ข้อยกเว้นสำหรับการป้องกัน

ผู้ดูแลระบบสามารถแจ้งให้ทาง GDCC Security Center ทำการ Add Exception ในบาง URL ที่ถูกระงับการเข้าถึงได้โดยการยืนยันการ Add Exception ซึ่งจะทำให้ URL ดังกล่าวอยู่นอกเหนือจากการป้องกันตามมาตรฐาน OWASP10:2021 ผู้ดูแลระบบโปรดยืนยันการดำเนินการ Add Exception มาในอีเมลนี้ ทาง GDCC Security Center จะดำเนินการยกเว้นการป้องกันให้ท่านทันที